

**Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО**

Факультет безопасности информационных технологий

Дисциплина:

«Технология сертификации средств защиты информации»

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ №1

«Статический анализ»

Выполнили:

Чу Ван Доан, студент группы N3447



(подпись)

Чан Бао Линь, студентка группы N3446



(подпись)

Доан Тхи Хоай Тхыонг, студентка группы N3445



(подпись)

Проверил:

Бегаев Алексей Николаевич, к.т.н. ФБИТ

(отметка о выполнении)

(подпись)

Санкт-Петербург

2026 г.

СОДЕРЖАНИЕ

Введение.....	3
1 Ход работы.....	4
1.1 Описание объекта оценки.....	4
1.2 Порядок выполнения работы.....	4
1.3 Описание выявленных CWE.....	5
1.3.1 CWE-570 Выражение всегда ложно.....	5
1.3.2 CWE-676 Использование потенциально опасной функции.....	5
1.3.3 CWE-481 Присваивание вместо сравнения.....	5
1.3.4 CWE-563 Присвоение переменной без использования.....	6
1.4 Разбор выявленных CWE с анализом корректности их срабатывания.....	6
1.4.1 CWE-570 Выражение всегда ложно.....	6
1.4.2 CWE-676 Использование потенциально опасной функции.....	9
1.4.3 CWE-481 Присваивание вместо сравнения.....	11
Заключение.....	14

ВВЕДЕНИЕ

Цель работы – провести статический анализ программного обеспечения.

Для достижения поставленной цели необходимо решить следующие задачи:

- описать объект оценки;
- при помощи инструмента “АК-ВС 3” провести сканирование заданного программного обеспечения, предоставить результаты с типами найденных уязвимостей (CWE) и количеством их срабатываний;
- описать выявленные CWE;
- предоставить участки кода, содержащие выявленные CWE с анализом корректности их срабатывания;
- сделать выводы о проделанной работе.

1 Ход работы

Вариант №14: leptonlib-1.67

1.1 Описание объекта оценки

Согласно нашему варианту, объектом оценки является пакет leptonlib-1.67. Он используется для работы с Leptonica, библиотекой языка C с открытым исходным кодом, содержащей программное обеспечение, применяемое в приложениях для обработки и анализа изображений.

1.2 Порядок выполнения работы

Для проведения сканирования заданного ПО на предмет уязвимостей был использован инструмент “АК-ВС 3”. Для начала работы мы создали проект, загрузили исходные файлы в .zip формате и указали следующие настройки проводимого анализа:

leptonlib-1.67

Настройка проекта

Уровень контроля

☐ 1 ☐ 2 ☐ 3 ☒ 4 ☐ 5

☐ Включить МКЧА и АЧКПВ

Типы анализа

☐ Статический и динамический анализ
☒ Только статический анализ

Настройка отчётов

☐ Вставлять исходный код в блок-схемы

В проекте обнаружены исходные коды на C/C++ без конфигурации.

Конфигурация по умолчанию для C/C++ парсера

☒ Не использовать конфигурацию по умолчанию
☐ Сформировать конфигурацию для Windows-проекта
☐ Сформировать конфигурацию для Linux-проекта

Выбор анализируемых языков

Название	Включён	Расширения файлов
C/C++	☒	c, cpp, cc, cxx, h, hpp, c++, hh, hxx, h++
C#	☒	cs
Java	☒	java

Рисунок 1 - Настройки созданного проекта в “АК-ВС 3”

По результатам сканирования загруженного пакета было обнаружено несколько уязвимостей, а также подсчитано количество их срабатываний в программном коде:

1. CWE-570: Выражение всегда ложно (кол-во срабатываний – 5);
2. CWE-676: Использование потенциально опасной функции (кол-во срабатываний – 5);
3. CWE-481: Присваивание вместо сравнения (кол-во срабатываний – 3);
4. CWE-563: Присвоение переменной без использования (кол-во срабатываний – 1).

[Назад к проекту "leptonlib-1.67"](#)

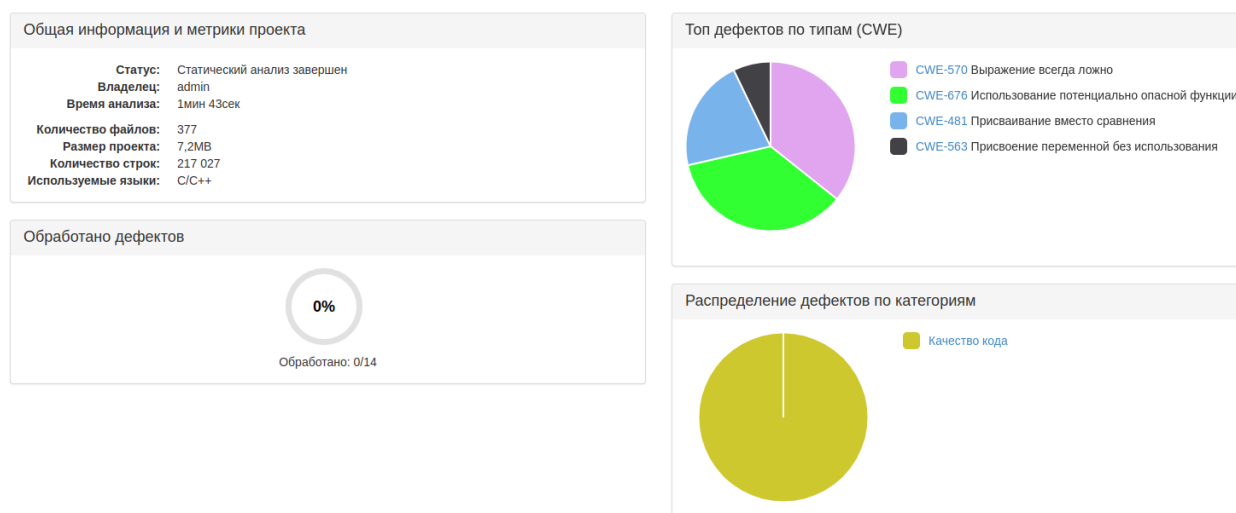


Рисунок 2 - Результаты статического анализа

1.3 Описание выявленных CWE

1.3.1 CWE-570 Выражение всегда ложно

Данная уязвимость предполагает наличие в коде логического выражения, которое при любом поведении программы принимает ложное значение. Таким образом, проверка такого выражения на истинность не имеет смысла и снижает эффективность потребления программой ресурсов.

1.3.2 CWE-676 Использование потенциально опасной функции

Данная уязвимость подразумевает использование в программе функции, имеющей уязвимость, которая при некорректном использовании этой функции может привести к непредсказуемому поведению программы и, как следствие, потере или искажению какой-либо информации.

1.3.3 CWE-481 Присваивание вместо сравнения

Как видно из названия, при данной уязвимости в процессе сравнения происходит операция присваивания вместо проверки на равенство. Такая ошибка в коде может

привести к неожиданному поведению программы из-за изменения значения переменной в момент исполнения, когда это не предполагается. В результате возможны некорректная работа программы, искажение или утеря данных.

1.3.4 CWE-563 Присвоение переменной без использования

Данная уязвимость заключается в том, что в программном коде происходит объявление переменной и, возможно, присвоение ей какого-либо значения, однако далее в ходе исполнения эта переменная нигде не используется либо ей присваивается новое значение без использования предыдущего. Такой недостаток кода приводит к неэффективному использованию оперативной памяти.

1.4 Разбор выявленных CWE с анализом корректности их срабатывания

По заданию лабораторной работы необходимо провести детальный разбор трёх найденных уязвимостей. Для этой цели мы отобрали уязвимости с наибольшим количеством срабатываний в коде программы.

1.4.1 CWE-570 Выражение всегда ложно

Описание выявленной уязвимости в рассматриваемом ПО:

Встроенный тип `uint32`, представляющий собой `unsigned int`, который может принимать значения в диапазоне `[0; 4294967295]`, проверяется на значение меньше нуля. Данное логическое выражение всегда будет ложным.

Таким образом, было выявлено верное срабатывание уязвимости. Она является недостатком кода, так как не может быть использована злоумышленником для эксплуатации.

leptonlib-1.67: просмотр дефекта

CWE-570: Выражение всегда ложно

Выражение всегда ложно. Сравнение со значением, находящимся вне диапазона для сравниваемого типа: '[0; 4294967295]'

Статус: Новый

Комментарий:

Применить

Путь до файла:

Выражение всегда ложно. Сравнение со значением, находящимся вне диапазона для сравниваемого типа: '[0; 4294967295]'

leptonlib-1.67/src/pix2.c:

677: `if (val < 0) {`

...

881: `if (val < 0) {`

Рисунок 3 - Информация о выявленной уязвимости CWE-570

```

663 pixSetAllArbitrary(PIX      *pix,
664                   l_uint32  val)
665 {
666     l_int32      n, i, j, w, h, d, wpl, npix;
667     l_uint32     maxval, wordval;
668     l_uint32     *data, *line;
669     PIXCMAP     *cmap;
670
671     PROCNAME("pixSetAllArbitrary");
672
673     if (!pix)
674         return ERROR_INT("pix not defined", procName, 1);
675     if ((cmap = pixGetColormap(pix)) != NULL) {
676         n = pixcmapGetCount(cmap);
677         if (val < 0) {
678             L_WARNING("index not in colormap; using first color", procName);
679             val = 0;
680         }
681         else if (val >= n) {
682             L_WARNING("index not in colormap; using last color", procName);
683             val = n - 1;
684         }
685     }
686
687     pixGetDimensions(pix, &w, &h, &d);
688     if (d == 32)
689         maxval = 0xffffffff;
690     else
691         maxval = (1 <= d) ? 1 : 0;

```

Рисунок 4 - Участок кода с выявленной уязвимостью CWE-570

leptonlib-1.67: отчёт о выявленных программных ошибках

Метод анализа: appchecker

Категория: Качество кода

CWE ID: 570

Тип дефекта: Выражение всегда ложно

Статус дефекта: Новое

Выражение всегда ложно. Сравнение со значением, находящимся вне диапазона для сравниваемого типа: '[0; 4294967295]'

leptonlib-1.67/src/pix2.c:

677: if (val < 0) {

...

881: if (val < 0) {

Метод анализа: appchecker

Категория: Качество кода

CWE ID: 570

Тип дефекта: Выражение всегда ложно

Статус дефекта: Новое

Выражение всегда ложно. Сравнение со значением, находящимся вне диапазона для сравниваемого типа: '[0; 4294967295]'

leptonlib-1.67/src/pix2.c:

692: if (val < 0) {

...

895: if (val < 0) {

Метод анализа: appchecker

Категория: Качество кода

CWE ID: 570

Тип дефекта: Выражение всегда ложно

Статус дефекта: Новое

Выражение всегда ложно. Сравнение со значением, находящимся вне диапазона для сравниваемого типа: '[0; 4294967295]'

leptonlib-1.67/src/pix3.c:

788: boxt = boxCreate(L_MAX(0, xc - dist / 2), L_MAX(0, yc - dist / 2),

leptonlib-1.67/src/enviro.h:

150: #define L_MAX(x,y) ((x) > (y)) ? (x) : (y))

Метод анализа: appchecker

Категория: Качество кода

CWE ID: 570

Тип дефекта: Выражение всегда ложно

Статус дефекта: Новое

Выражение всегда ложно. Сравнение со значением, находящимся вне диапазона для сравниваемого типа: '[0; 4294967295]'

leptonlib-1.67/src/numabasic.c:

1888: if (key < 0)

Метод анализа: appchecker

Категория: Качество кода

CWE ID: 570

Тип дефекта: Выражение всегда ложно

Статус дефекта: Новое

Выражение всегда ложно. Сравнение со значением, находящимся вне диапазона для сравниваемого типа: '[0; 4294967295]'

leptonlib-1.67/src/textops.c:

105: if (val < 0)

...

261: if (val < 0)

...

367: if (val < 0) {

Рисунок 5 - Полный список выявленных уязвимостей CWE-570

Переменная `key` (четвёртое срабатывание) имеет тот же тип, что и переменная `val` в рассмотренном выше случае. Аналогично, внутри функции `L_MAX` (третье срабатывание) происходит сравнение значения, имеющего тип `l_uint32`, с нулём.

1.4.2 CWE-676 Использование потенциально опасной функции

Описание выявленной уязвимости в рассматриваемом ПО:

Встроенная функция `system()` исполняет переданную в качестве аргумента команду при помощи обработчика команд, характерного для текущей операционной системы. Использование данной функции является плохой практикой, так как с ее помощью злоумышленник получает возможность выполнять сторонний код.

Таким образом, было выявлено верное срабатывание, и его можно отнести к уязвимостям. В конкретно этом случае злоумышленник может выполнить spoofing-атаку (например, посредством `alias`) на выполняемую легитимную команду с целью подмены её на вредоносную.

Аналогично предыдущему пункту, мы рассмотрели только одно из срабатываний, так как во всех выявленных случаях была использована одна и та же уязвимая функция.

leptonlib-1.67: отчёт о выявленных программных ошибках

Метод анализа: appchecker

Категория: Качество кода

CWE ID: 676

Тип дефекта: Использование потенциально опасной функции

Статус дефекта: Новое

Не используйте функции system/popen

leptonlib-1.67/src/writefile.c:

737: ignore = system(buffer);

...

930: ignore = system(buffer);

Метод анализа: appchecker

Категория: Качество кода

CWE ID: 676

Тип дефекта: Использование потенциально опасной функции

Статус дефекта: Новое

Не используйте функции system/popen

leptonlib-1.67/src/writefile.c:

781: ignore = system(buffer);

...

844: ignore = system(buffer);

Метод анализа: appchecker

Категория: Качество кода

CWE ID: 676

Тип дефекта: Использование потенциально опасной функции

Статус дефекта: Новое

Не используйте функции system/popen

leptonlib-1.67/src/viewfiles.c:

106: ignore = system(charbuf);

Метод анализа: appchecker

Категория: Качество кода

CWE ID: 676

Тип дефекта: Использование потенциально опасной функции

Статус дефекта: Новое

Не используйте функции system/popen

leptonlib-1.67/src/xtractprotos.c:

108: ret = system(buf);

Метод анализа: appchecker

Категория: Качество кода

CWE ID: 676

Тип дефекта: Использование потенциально опасной функции

Статус дефекта: Новое

Не используйте функции system/popen

leptonlib-1.67/src/gplot.c:

374: ignore = system(buf);

Рисунок 6 - Полный список выявленных уязвимостей CWE-676

```

729         else
730             pixt = pixScale(pixs, ratmin, ratmin);
731         if (!pixt)
732             return ERROR_INT("pixt not made", procName, 1);
733     }
734
735     if (index == 0) {
736         snprintf(buffer, L_BUF_SIZE, "rm -f /tmp/junk_display.*");
737         ignore = system(buffer);
738     }
739
740     index++;
741     if (pixGetDepth(pixt) < 8 ||
742         (w < MAX_SIZE_FOR_PNG && h < MAX_SIZE_FOR_PNG)) {
743         snprintf(buffer, L_BUF_SIZE, "/tmp/junk_display.%03d.png", index);
744         pixWrite(buffer, pixt, IFF_PNG);
745     }

```

Рисунок 7 - Участок кода с выявленной уязвимостью CWE-676

1.4.3 CWE-481 Присваивание вместо сравнения

Описание выявленной уязвимости в рассматриваемом ПО:

Передаваемое в функцию `pixGetComponentRange()` в качестве параметра переменная `color` вместо выражения сравнения (`==`) подвергается операции присвоения (`=`). По этой причине из нескольких блоков `else-if` всегда выполняется только первый, так как в его логическом условии происходит операция, дающая в результате положительное число.

Таким образом, срабатывание верное и является недостатком кода, так как уязвимость не может быть использована злоумышленником, а сказывается только на некорректной работе программы.

Был рассмотрен только один случай, так как все 3 срабатывания этого типа уязвимости входят в один блок `if-else` и, следовательно, ведут себя аналогичным образом.

leptonlib-1.67: отчёт о выявленных программных ошибках

Метод анализа: appchecker

Категория: Качество кода

CWE ID: 481

Тип дефекта: Присваивание вместо сравнения

Статус дефекта: Новое

Код, использующий оператор присваивания вместо сравнения.

leptonlib-1.67/src/pix4.c:

1465: } else if (color = L_SELECT_RED) {

Метод анализа: appchecker

Категория: Качество кода

CWE ID: 481

Тип дефекта: Присваивание вместо сравнения

Статус дефекта: Новое

Код, использующий оператор присваивания вместо сравнения.

leptonlib-1.67/src/pix4.c:

1471: else if (color = L_SELECT_GREEN) {

Метод анализа: appchecker

Категория: Качество кода

CWE ID: 481

Тип дефекта: Присваивание вместо сравнения

Статус дефекта: Новое

Код, использующий оператор присваивания вместо сравнения.

leptonlib-1.67/src/pix4.c:

1477: else if (color = L_SELECT_BLUE) {

Рисунок 8 - Полный список выявленных уязвимостей CWE-481

```

1432 pixGetComponentRange(PIX      *pixs,
1433                    l_int32   factor,
1434                    l_int32   color,
1435                    l_int32   *pminval,
1436                    l_int32   *pmaxval)
1437 {
1438     l_int32   d;
1439     PIXCMAP  *cmap;
1440
1441     PROCNAME("pixGetComponentRange");
1442
1443     if (pminval) *pminval = 0;
1444     if (pmaxval) *pmaxval = 0;
1445     if (!pminval && !pmaxval)
1446         return ERROR_INT("no result requested", procName, 1);
1447     if (!pixs)
1448         return ERROR_INT("pixs not defined", procName, 1);
1449
1450     cmap = pixGetColormap(pixs);
1451     if (cmap)
1452         return pixcmapGetComponentRange(cmap, color, pminval, pmaxval);
1453
1454     if (factor < 1)
1455         return ERROR_INT("subsampling factor < 1", procName, 1);
1456     d = pixGetDepth(pixs);
1457     if (d != 8 && d != 32)
1458         return ERROR_INT("pixs not 8 or 32 bpp", procName, 1);
1459
1460     if (d == 8) {
1461         pixGetExtremeValue(pixs, factor, L_SELECT_MIN,
1462                           NULL, NULL, NULL, pminval);
1463         pixGetExtremeValue(pixs, factor, L_SELECT_MAX,
1464                           NULL, NULL, NULL, pmaxval);
1465     } else if (color == L_SELECT_RED) {
1466         pixGetExtremeValue(pixs, factor, L_SELECT_MIN,
1467                           pminval, NULL, NULL, NULL);
1468         pixGetExtremeValue(pixs, factor, L_SELECT_MAX,
1469                           pmaxval, NULL, NULL, NULL);
1470     }
1471     else if (color == L_SELECT_GREEN) {
1472         pixGetExtremeValue(pixs, factor, L_SELECT_MIN,
1473                           NULL, pminval, NULL, NULL);
1474         pixGetExtremeValue(pixs, factor, L_SELECT_MAX,
1475                           NULL, pmaxval, NULL, NULL);
1476     }
1477     else if (color == L_SELECT_BLUE) {
1478         pixGetExtremeValue(pixs, factor, L_SELECT_MIN,
1479                           NULL, NULL, pminval, NULL);
1480         pixGetExtremeValue(pixs, factor, L_SELECT_MAX,
1481                           NULL, NULL, pmaxval, NULL);
1482     }
1483     else
1484         return ERROR_INT("invalid color", procName, 1);
1485
1486     return 0;
1487 }

```

Рисунок 9 - Участок кода с выявленной уязвимостью CWE-481

ЗАКЛЮЧЕНИЕ

В ходе выполнения лабораторной работы при помощи инструмента “АК-ВС 3” был проведён статический анализ пакета leptonlib-1.67 и выявлены некоторые уязвимости в программном коде. Три наиболее часто встречаемых типа CWE были проанализированы на предмет корректности срабатывания и степень потенциальной опасности найденной уязвимости. В результате все рассматриваемые случаи были определены верно, но только CWE-676 является уязвимостью, в то время как остальные являются лишь недостатком кода.